



5 Common Cyber Attacks EDRs Miss



ReliaQuest
Threat Research

A detailed analysis of **5 common attack types** that can make it past your EDR tools—including email account takeover, insider threats, and more—and actionable ways to combat them.

Executive Summary



Endpoint Detection and Response

EDR is essential for detecting and responding to cyber threats in realtime, but it is not foolproof, and must be complemented by additional security measures to address gaps and sophisticated attacks. Several types of attacks can exploit its limitations to evade detection.



Email Account Takeover (ATO)

Email account takeover (ATO) is a threat that affects a critical tool for our daily communication. Instead of impacting the endpoint, threat actors are often able to exploit user behavior to compromise email accounts. EDR typically does not have the ability to monitor and analyze activities within web-based email services or cloud email platforms. Email ATO contributes to the growth of business email compromise (BEC), which skyrocketed 246% between February 2023 and February 2024, as observed by ReliaQuest.



Adversary-in-the-Middle (AITM) Attacks

Adversary-in-the-middle (AITM) attacks, in which an attacker intercepts and alters communications between two parties who believe they are directly interacting with each other, can also bypass detection by EDR solutions. AITM methodologies and tools are popular topics on cybercriminal forums; ReliaQuest observed significant threat actor interest towards the “EvilGinx” method, which involves setting up a phishing site that proxies the legitimate login page, capturing both login credentials and MFA tokens in real time. AITM attacks often fly under the radar of EDR because the attacks typically occur at the network rather than endpoint level.



Cloud Storage Attacks

Cloud storage attacks threaten data security, privacy, and integrity, causing breaches, financial losses, and reputational damage. When harmful content is stored on widely used cloud services, it might not undergo thorough scanning by EDR systems. EDR tools often whitelist popular cloud platforms, assuming they’re primarily used for legitimate purposes. In February 2024, ReliaQuest mitigated a sophisticated “Amarok” ransomware attack initiated via a compressed file stored in Google Docs. Understanding and mitigating these risks is crucial for maintaining trust and compliance, particularly as organizations increasingly adopt cloud-based services.



Software-as-a-Service (SaaS) Attacks

Software-as-a-Service (SaaS) Attacks have been observed exploiting the relationship between customers and suppliers of software-as-a-service (SaaS) platforms, which is typically beyond a traditional EDR’s scope of visibility. “Scattered Spider,” a financially motivated cybercriminal threat group, uses SaaS providers like vSphere and Azure to create new virtual machines, utilizing their admin privileges to configure these machines while disabling security protections like Microsoft Defender and other telemetry tools. Keeping abreast of the tactics, techniques, and procedures (TTPs) of groups like Scattered Spider is essential, as these adversaries quickly adapt their techniques as defenders change theirs.



Insider Threats

Insider threats can be particularly pernicious because the perpetrator is often fully aware of the organization’s security measures, including EDR, and can adapt to circumvent them. Unlike typical external threat actors, insiders may have a personal vendetta, making their actions more targeted and deliberate. In one observed case study, ReliaQuest identified a probable insider using the file transfer protocol (FTP) for data exfiltration purposes.

Table of Contents

Introduction 1

Email Account Takeover 2

 Case Study.....4

 Mitigations and Recommendations.....5

Adversary-in-the-Middle Attacks 6

 Case Study.....7

 Mitigations and Recommendations.....8

Cloud Storage Solutions 9

 Case Study.....10

 Mitigations and Recommendations.....11

Targeting Software-as-a-Service Providers 12

 Case Study.....13

 Mitigations and Recommendations.....14

Insider Threats 15

 Case Study.....16

 Mitigations and Recommendations.....17

Conclusion..... 18

Appendix: Endnotes..... 19

Introduction

Endpoint protection serves as the frontline defense for individual devices that connect to networks, like computers, mobile phones, and tablets.

Endpoint security measures—typically comprising antivirus software, firewalls, and intrusion detection systems (IDS)—play a vital role in safeguarding sensitive data and maintaining the overall cyber hygiene of an organization.

EDR (endpoint detection and response) software is a subset of this, continually monitoring data from endpoints for specific threat signatures or behaviors to detect, investigate, and respond to potential security threats in real time.

However, EDR is not foolproof. EDR tools can miss sophisticated or zero-day threats that exploit unknown vulnerabilities, since these may not match known threat signatures or behavior patterns. Additionally, EDR tools' effectiveness relies heavily on timely updates and accurate threat intelligence, and any lag in these areas can create gaps in protection.

There are also physical and virtual appliances that cannot be visible for EDR agents for purposes of operational efficiency, reliability, and performance (e.g., appliances designed for specific tasks requiring optimum efficiency, like load balancers or firewalls). Attackers can also avoid detection by circumventing the endpoint altogether. Think of EDR as a high-tech security camera system for your digital world:

It catches a lot, but a clever thief might still find a way in. It's essential, but just one piece of your overall security puzzle.

Email-based threats, including phishing and other social engineering attacks, often exploit human error and social engineering tactics to deliver malicious payloads directly to users, facilitating evasion from EDR mechanisms. Adversary-in-the-middle (AITM) attacks bypass EDR by intercepting and manipulating communication between endpoints, evading detection through disguised and seemingly legitimate traffic. ReliaQuest has observed the abuse of cloud storage services as a prevalent vector, with attackers leveraging trusted platforms to host and distribute malware, making detection challenging for EDR systems that rely on endpoint visibility.

Live attacks increasingly exploit organizations' relationships with software-as-a-service (SaaS) providers—abuse that EDR solutions struggle to detect—while insider threats remain a pervasive issue. These issues impact all sectors and geographies and are ubiquitous for all business using EDR systems. While endpoint protection is essential, it should be part of a broader, multilayered cybersecurity strategy.

Organizations should implement a defense-in-depth approach to ensure comprehensive protection against cyber threats:



User Education



Network Security



Regular System Updates

In this report, we further outline the attack types above.

For each, we provide:

- In-depth analysis
- Case study
- Takeaways for defenders
- Effective mitigations

Email Account Takeover

Email ATO occurs when an unauthorized party gains control of a legitimate user's email account. The adversary can then sell the compromised email account credentials on cybercriminal platforms or use the email account for numerous malicious activities, including data exfiltration, further phishing attacks, or business email compromise (BEC)—a trending attack type that increased by 246% between February 2023 and February 2024, according to our data.

A typical email ATO attack lifecycle is shown in Figure 1:

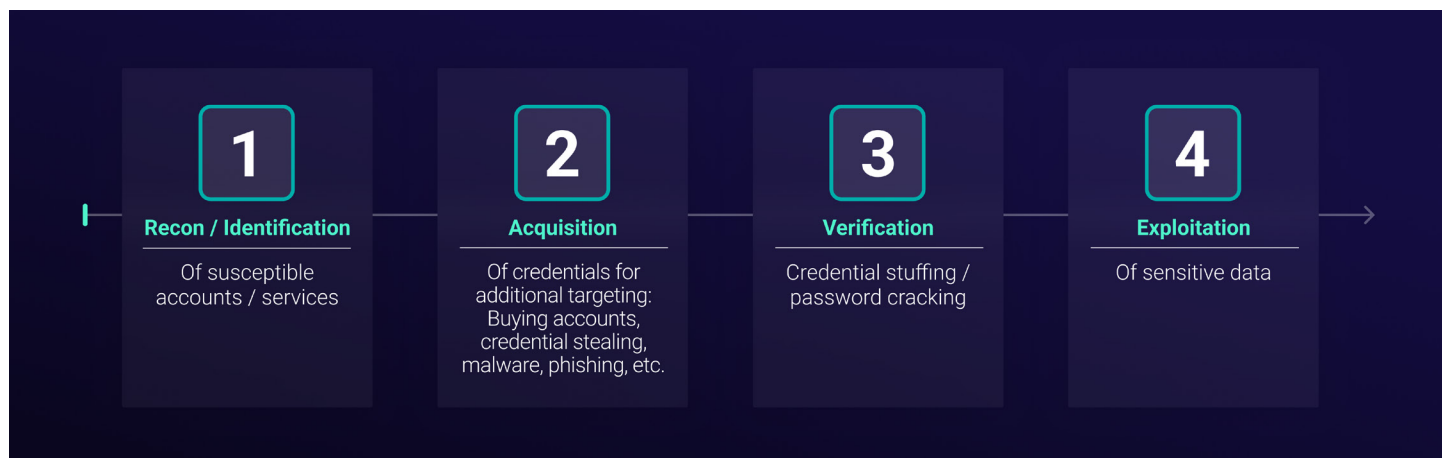


Figure 1: Email ATO attack lifecycle

Email ATO can affect enterprise or home users and may lead to the compromise of associated accounts, like those for social media or banking. A representative data set of true-positive ReliaQuest customer incidents revealed that in Q2 2024:

56% of identified initial access techniques involved a form of phishing, highlighting the significance of email-related threats.

Because email ATO attacks do not involve directly compromising the endpoint device, they are not picked up by EDRs. Instead of deploying malware or exploiting vulnerabilities on the user's device, attackers typically focus on exploiting user behavior and the inherent flaws within the email service itself—gaining access via phishing schemes, credential stuffing, or exploiting weak or reused passwords.

Once they have acquired login credentials, a threat actor can discreetly access and manipulate the email account remotely through web interfaces, effectively sidestepping endpoint security measures like antivirus software or firewalls and avoiding triggering alerts based on changes to endpoint systems. In addition, EDR solutions may not have the capability to monitor and analyze activities within web-based email services or cloud email platforms.

For cybersecurity defenders, the ubiquity of email in business operations presents a critical weakness. Exploiting email services is the most straightforward—and most frequently exploited—avenue for attackers to infiltrate targeted networks. The ease with which email ATO can be executed is alarming: Threat actors can craft highly convincing emails with minimal effort, often leveraging prepackaged phishing templates provided by phishing-as-a-service tools (PhaaS).

This is just one of many ways to perform ATO—other methods include [credential stuffing](#), brute-forcing, or using [information-stealing malware](#). Other threat actors were identified advertising vulnerabilities—in the example below, a cross-site-scripting (XSS) vulnerability—to perform email ATO, demonstrating the diverse methods threat actors can use to take over an account.

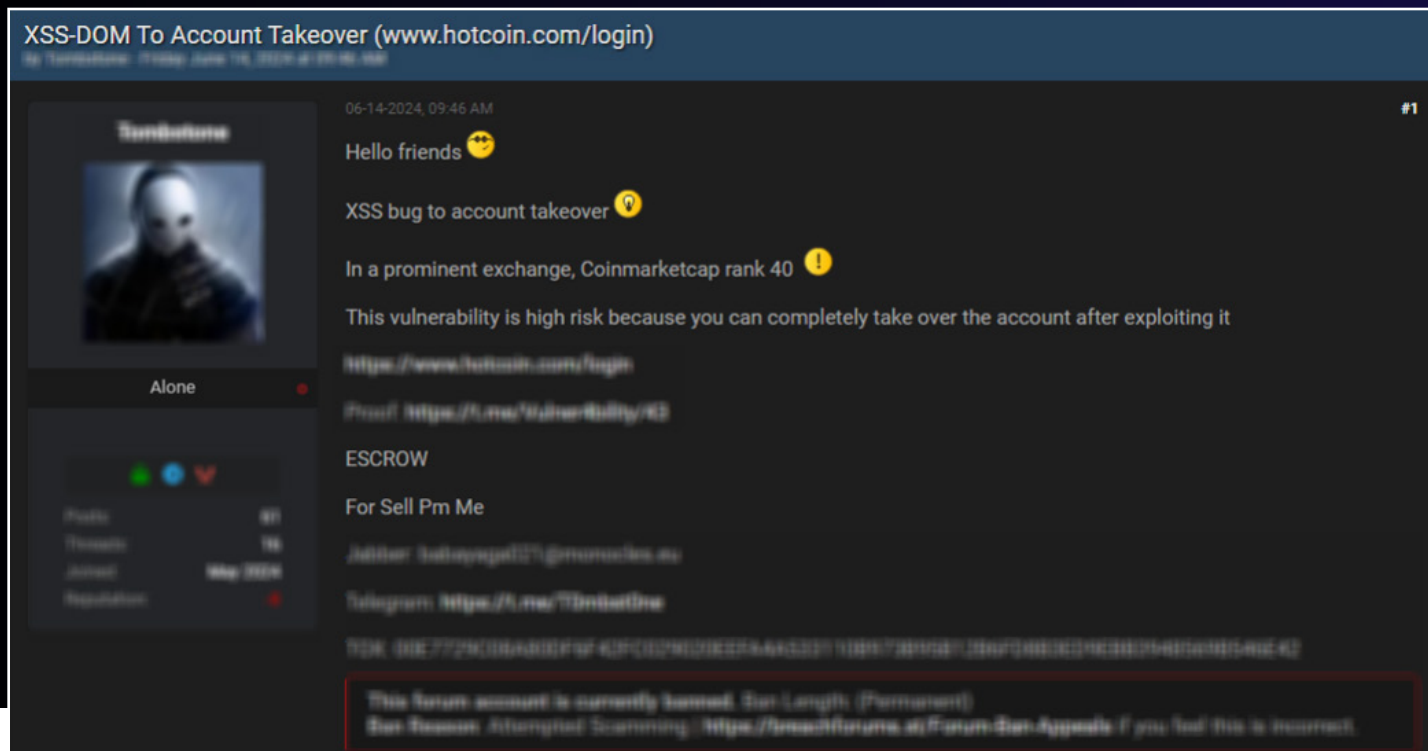


Figure 2: Cybercriminal forum user advertising XSS vulnerability to achieve ATO

Implementing multifactor authentication (MFA) is a common recommendation against email ATO attacks. However, threat actors can [bypass authentication controls like MFA](#) to compromise accounts with this safety measure in place. Advanced authentication measures like Zero Trust architectural models¹ offer additional security checks, but most organizations are far from adopting these measures.

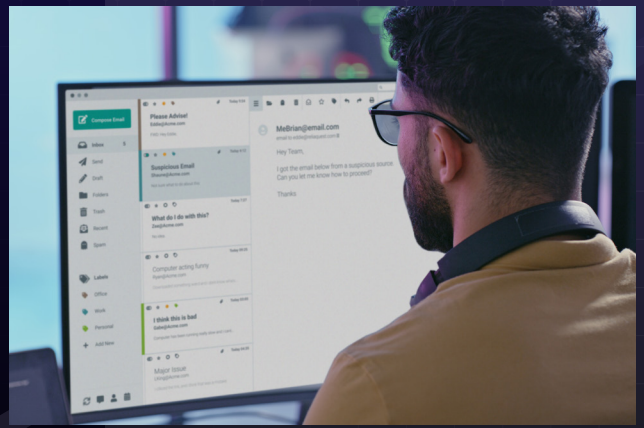
Detecting and responding to such attacks is challenging, emphasizing the need for email-based controls (including DMARC, DKIM, and SPF) and continuous monitoring of unusual access patterns or account activities.



Case Study

In May 2024, ReliaQuest investigated a customer incident involving an email ATO.

We identified a suspicious email Outlook rule that appeared to have been created or modified by a legitimate user.



The rule was named “[.]” and would move all emails to the “[Conversation History]” folder if the subject or body contained anything that would signal to the mailbox’s legitimate user that something suspicious had occurred, e.g., words like “hacked” or “compromised.” An attacker likely created this rule so that they could send ostensibly legitimate emails without the account holder noticing. This is a common tactic in BEC attacks. In addition, the source IP cited in this activity was registered to Microsoft, indicating that the threat actor was using Microsoft’s network to mask their true source IP—another hallmark of BEC.

ReliaQuest responded by terminating the user’s session, rotating credentials, and reverting the email inbox rule along with any other actions taken by the attacker (including removing any fraudulent MFA devices registered to the user’s account). ReliaQuest identified the original email address used to compromise the user’s device and blocked indicators of compromise (IoCs) associated with the email.

While EDR solutions excel at monitoring and analyzing system-level activities—such as file modifications, process executions, and network communications—to detect and counter threats, email rules are a significant blind spot.

EDR solutions cannot detect changes to email rules, which are typically configured within email client applications or cloud-based email services rather than on the endpoint itself.

As a result, any manipulations to email rules elude the detection capabilities of EDR, creating a dangerous gap in organizations’ cybersecurity defenses.

Email rules that appear unnecessary or overly specific—especially those that divert emails related to security alerts—should be treated with extreme suspicion. Another red flag is the creation of rules that forward emails to external addresses, a tactic often employed by BEC attackers. These rules may target emails containing financial or business information, facilitating fraudulent activities. Recognizing the potential for abuse of email inbox rules is critical. Attackers can exploit these rules to redirect, delete, or hide emails, allowing them to conduct malicious activities undetected and compromise sensitive information. By manipulating these settings, cybercriminals can bypass traditional security measures, enabling extensive and covert damage to an organization.

Mitigations and Recommendations

The following detection rules and respond plays showcase some of the tools available to ReliaQuest customers for mitigating email-based threats.

Detection Rule: RQ – Allowed Phishing Email

MITRE Attack ID:	Summary:
TA0001: T1566.002 – Spearphishing Link	Email gateways often contain threat reputation lists, sandboxes, and other signature-based solutions that attempt to identify emails as malicious. This alert detects when this activity is not blocked prior to reaching the user's inbox as there is risk of compromise.
TA0043: T1598.003 – Spearphishing Link	

Detection Rule: RQ – Office 365 File Shared Outside Organization

MITRE Attack ID:	Summary:
TA0009: T1213.002 – SharePoint Mapping	Files shared on SharePoint or OneDrive with a user that is outside of the organization could allow unauthorized access by outside users to sensitive data. This alert detects any invitation-created event indicating a file being shared externally.

Detection Rule: RQ – Allowed Attachment with Suspicious Extension

MITRE Attack ID:	Summary:
TA0001: T1566.001 – Spearphishing Attachment	Email gateways are getting progressively better at identifying and blocking known extensions that commonly are used for phishing. Some of these extensions are not blocked and allowed to make it to the user's inbox. Detection of these critical file extensions can result in remediation prior to the user opening the attachment. This rule detects when suspicious file attachments, such as executable files, disk image files, and files with double extensions, are allowed by the email server.
TA0005: T1027.012 – LNK Icon Smuggling	

Containment / Respond Play



Send Malicious Response:

Sends Malicious Email Response to reporter, permitting triage as a potential incident and raising visibility of the threat.



Block Domain:

Allows a user to add a domain to a threat list and block it. With email-based threats, this assists in interrupting the attacker's chain of actions.



Delete Email Attachment:

Deletes the specified attachment from email; this reduces the chance of the suspicious attachment being opened and propagating a threat.



Terminate Active Sessions:

Terminates sessions identified as being compromised, removing the threat actor's ability to continue their activity.

MFA provides the most significant protection against email-based threats, but defenders should also consider the following recommendations.



Email Account Monitoring Tools:

Email account monitoring tools can detect changes to email rules, permissions, and other settings.



Using Group Policy Objects (GPOs): Administrators can configure settings to prevent users from saving passwords in their web browsers, thereby enhancing security and reducing the risk of credential theft. This mitigates the lack of visibility from EDR by preventing credential storage that could be exploited without endpoint-level detection.



Digital Risk Protection: Using digital risk protection (DRP) software assists in detecting credential exposure by continuously monitoring external sources such as the dark web, social media, and online forums for compromised credentials and other sensitive information related to the organization.

Adversary-in-the-Middle Attacks

AITM attacks are a subset of the man-in-the-middle (MITM) attack methodology, in which an attacker intercepts and alters communications between two parties who believe they are directly interacting with each other. This interception can occur in several ways, including via compromised public Wi-Fi networks, using spoofing techniques, or through software vulnerabilities. The attacker might eavesdrop on the exchanged information, steal sensitive data like login credentials and credit card numbers, or inject malicious data into the communication stream to mislead the parties or manipulate actions. AITM attacks take this concept further by actively manipulating the communication or transaction process to deceive the users, often to bypass multifactor authentication or to steal sensitive information in real time.

AITM attacks often occur at the network level rather than the endpoint level. Since EDR tools are not designed to inspect and analyze the content of network traffic in transit, they lack the visibility required to detect the subtle manipulations and interceptions characteristic of AITM attacks.

Consequently, without complementary network-level detection tools, such as intrusion detection systems (IDS) or specialized network monitoring solutions, EDR alone may be insufficient to identify and mitigate these sophisticated attacks.

AITM methodologies and tools are popular topics on cybercriminal forums, highlighting the real-world threat this attack type poses. We've seen users advertising services for various MITM methodologies, including targeting individual websites via simple PHP webpage cloning or high-quality services featuring customization options, with prices ranging from \$300 to \$1,000 per service.

Elsewhere, forum members shared advice on using "EvilGinx," a MITM attack framework that involves the attacker setting up a phishing site that proxies the legitimate login page, capturing both login credentials and MFA tokens in real time and enabling authenticated access to the target account (see Figure 3).

EvilGinx's popularity on dark-web platforms emphasizes that cybercriminals with even rudimentary skills can facilitate account theft and bypass security measures. This attack type is so important to remediate because AITM attacks can intercept, manipulate, and potentially exfiltrate sensitive data during transmission, leading to severe consequences such as data breaches, credential theft, and unauthorized access to confidential communications.

Since EDR solutions lack the capability to detect these network-level threats, attackers can exploit this weakness to carry out their malicious activities undetected, undermining an organization's overall security posture.

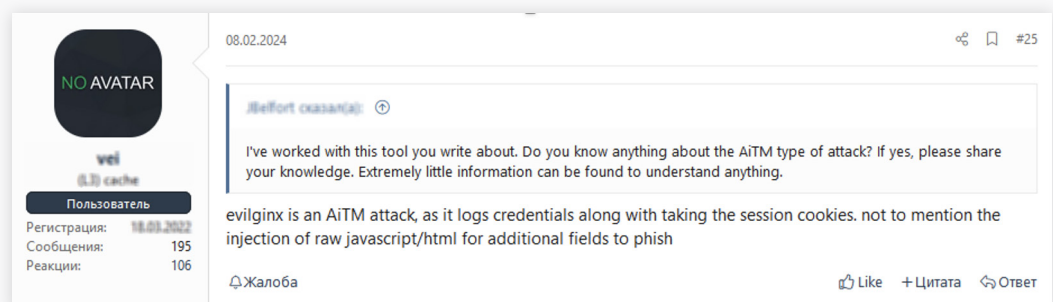


Figure 3: Cybercriminal forum post discussing EvilGinx

Case Study

In July 2024, ReliaQuest observed a series of AITM phishing attacks related to Axios, a promise-based HTTP client for browsers and node.js.²

These attacks began with the target receiving an email from a legitimate but compromised account that contained a link to a phishing site masquerading as a Microsoft webpage.



Upon interacting with the link, the recipient was redirected to a Cloudflare URL. After completing a CAPTCHA, they were presented with a fake Microsoft login page. These types of attacks are alarmingly common, exploiting widely trusted services and relationships, facilitating the interception of sensitive information and unauthorized access to valuable accounts.

ReliaQuest uncovered the connection to Axios through the observation of a user agent string, which was further traced to ISPs located in Russia. These ISPs were associated with older versions of Axios, such as 1.6.8, and another user agent string, "BAV2ROPC," linked to a legacy Microsoft authentication protocol frequently exploited by threat actors for password spraying attacks. Once the victim entered their credentials on the phishing page, the Axios infrastructure captured them, likely along with their session token, completing the AITM attack.

In this case study, the redirection to a Cloudflare URL and the subsequent presentation of a fake Microsoft login page occurred within the web browser and over the network, bypassing endpoint-level scrutiny. The use of legitimate services like Cloudflare, combined with user agent strings associated with older versions of Axios—often considered benign—further obfuscated the attack.

These types of sophisticated approaches are exceedingly difficult for EDR solutions to recognize and flag these activities as malicious.

These attacks are particularly prevalent because they exploit the trust users place in legitimate accounts, making suspicious activities harder to detect. By using Cloudflare as an intermediary, the attackers add a layer of authenticity, leveraging the reputation of a well-known and trusted vendor. Additionally, the likely capture of session tokens highlights a common tactic used by threat actors to bypass MFA. While MFA provides significant protection against email-based threats, it is not foolproof, and attackers continuously evolve their methods to circumvent it.

Mitigations and Recommendations

The following detection rules and respond plays highlight some of the tools available to ReliaQuest customers for mitigating AITM attacks.

Detection Rule: RQ – Anomalous Session Activity

MITRE Attack ID:

TA0005: T1564.008 –
Email Hiding Rules

TA0001: T1078 –
Valid Accounts

Summary:

This detection evaluates the time between a 'Keep me signed in' event and a 'Login:reprocess' event (token replay) within the same unique session ID. It is highly unlikely that a legitimate user would engage in this type of back-to-back authentication within the same session.

Detection Rule:

RQ – Phishing Link Clicked Followed by Multifactor Authentication

MITRE Attack ID:

TA0001: T1566.002 –
Spearphishing Link

TA0008: T1534 –
Internal Spearphishing

TA0043: T1598.003 –
Spearphishing Link

TA0043: T1598.002 –
Spearphishing
Attachment

Summary:

One of the few ways that an attacker can get past multifactor authentication is to phish a user and direct them to type in their credentials to a fake website, then prompt the user to authenticate. This rule detects a malicious URL in an email that was clicked by a user and allowed, followed by a user successfully authenticating.

Detection Rule:

RQ – Multiple Client Logins from Geographically Different Locations

MITRE Attack ID:

T1078.002 – Valid
Account: Domain
Accounts

Summary:

Users logging on from multiple locations in a short period of time can indicate that a threat actor has compromised the account in a location other than where the user typically is located. This rule detects when a user has logged into the environment from multiple locations in a distinct timespan, showcasing impossible travel occurring.

Containment / Respond Play



Terminate Active Sessions:

Terminates user's active sign-in session and revokes all cookies. This assists in revoking the threat actor's access to the compromised account.



Reset Password:

Resets the user's password when their account is compromised, preventing the threat actor from further authenticating.



Block IP:

Blocks an IP associated with malicious session activity, isolating the threat actor from their infrastructure and hindering their ability to continue activity.

AITM attacks can be executed using various techniques. The most effective strategies for enhancing resilience against these attacks involve implementing robust end-to-end encryption for data and services.



Use of HTTPS: Websites should use strong, up-to-date SSL/TLS certificates. Users should be educated to check for HTTPS in the URL and look for valid certificates, especially when entering sensitive information. Ensuring the use of HTTPS mitigates EDR's inability to detect web-based attacks by encrypting data transmitted between clients and servers, reducing the risk of interception and manipulation by attackers and ensuring the integrity and confidentiality of the communication.



Approved Corporate Virtual Private Networks (VPNs): Individuals and organizations should use only approved corporate VPNs to safeguard their internet connections, especially when using public Wi-Fi networks, which are common hotspots for MITM attacks. Encrypting all internet traffic reduces the risk of interception and eavesdropping by attackers while providing an additional layer of security for remote connections.



Content Security Policy (CSP): CSP can help stop AITM attacks and mitigate visibility gaps in EDR solutions by restricting and monitoring the sources of web content, preventing unauthorized scripts from executing, and enhancing overall threat detection.

Cloud Storage Solutions

Threat actors often abuse cloud storage services like Dropbox or Google Drive to distribute malware, exfiltrate sensitive data, or facilitate command-and-control (C2) operations. Attackers may upload malicious files and share them via links, email attachments, or embedded websites to trick users into downloading harmful software, thereby bypassing traditional security measures like EDR. They can also use these services to exfiltrate stolen data, avoiding detection by security tools that might flag large data transfers to unfamiliar servers.

Additionally, advanced malware may use cloud storage for C2 communications, blending in with legitimate traffic to evade detection. Phishing campaigns frequently incorporate cloud storage links to appear more credible, further increasing the risk of compromise. When these links or files are shared, the recipient might not suspect anything malicious and might be more likely to open them because they appear to come from a seemingly legitimate, secure source.

When malicious content is hosted on a commonly used cloud service, it may not be scanned as rigorously by EDR systems, which often whitelist popular cloud tools due to their common use in legitimate operations. Despite the best efforts of cloud storage providers to remove malware and malicious content from their services, they have several limitations. While services like Dropbox and Google Drive use advanced malware detection tools, these technologies are not perfect. They often rely on signature-based detection, which compares files against databases of known malware “signatures.” New or significantly altered malware might not be recognized if it hasn’t yet been added to the database. Threat actors can also encrypt material hosted to cloud storage services, obfuscating them from malware scanning tools. Continuous scanning of every single file by every user can also be resource intensive.

Cloud storage solutions are prime targets for cyberattacks

Attackers exploit the inherent trust in the domain’s reputation to bypass initial security checks, making it easier to infiltrate systems undetected. By abusing the scale of the cloud service’s customer base, attackers can reach a broader audience, providing them with more time on target before potential detection. This enables the attackers to scale their operations rapidly and efficiently, amplifying the impact of their malicious activities.

Case Study

In February 2024, ReliaQuest tackled a customer incident involving a sophisticated attack chain linked to “Amarok” ransomware.

The attack began with a phishing email that delivered compressed malicious files via Google Docs, likely to obfuscate their content.



Once executed, these files launched winlogon.exe and authenticated using admin credentials. The attacker then stole browser credentials and planted files in the startup directory. The payload subsequently executed the command “vssadmin.exe Delete Shadows /All /Quiet,” silently deleting all Volume Shadow Copies on the computer. This feature in Microsoft Windows creates backup copies or snapshots of files and volumes for recovery purposes.

By eliminating these backups, the attacker severely hindered recovery efforts. To mitigate the attack, ReliaQuest swiftly isolated the compromised host, removed malicious artifacts, blocked the sending address, revoked active sessions for the affected user, and rotated their credentials. This rapid response was crucial in containing the attack and preventing further damage.

EDR might not have detected this incident due to the adversary’s use of sophisticated obfuscation techniques and legitimate system utilities. By compressing malicious files via Google Docs, they bypassed traditional signature-based detection methods. The execution of winlogon.exe and vssadmin.exe, both legitimate Windows processes, further obscured the malicious activity. Moreover, the use of admin credentials to steal browser credentials and create startup files likely appeared as normal administrative actions, evading EDR’s behavioral analysis. The deletion of Volume Shadow Copies using the legitimate command vssadmin.exe also likely went unnoticed without specific monitoring rules for such actions. This combination of obfuscation, legitimate utilities, and administrative privileges enabled the attacker to carry out their activities under the radar, highlighting the limitations of EDR solutions in detecting such well-crafted attacks.

Cloud-based storage attacks pose significant risks to the security, privacy, and integrity of sensitive data stored in the cloud. These attacks can result in data breaches, financial losses, regulatory penalties, and severe damage to an organization’s reputation. As businesses increasingly rely on cloud services, understanding and mitigating these risks is crucial for maintaining trust, ensuring compliance, and protecting valuable information from cyber threats. Detecting the compression of files within cloud-based applications like Google Docs typically requires specialized cloud security solutions, such as cloud access security brokers (CASBs) or native security tools provided by the cloud service provider. These solutions monitor and analyze activities within the cloud environment for unusual or unauthorized actions.

The abuse of legitimate cloud services emphasizes the importance of implementing robust cloud security practices and monitoring solutions to detect and mitigate threats within cloud environments. Attackers are continually refining their techniques to better evade detection, often exploiting legitimate solutions in ways that fall outside the visibility of traditional security systems. Such incidents highlight the need for comprehensive security strategies that encompass both on-premises and cloud-based assets. Organizations must prioritize continuous monitoring and auditing of cloud activities and educate users about the risks associated with cloud services.

Mitigations and Recommendations

The following detection rules and respond plays showcase some of the tools available to ReliaQuest customers for mitigating cloud-based threats.

Detection Rule: RQ – Malware Detection in Cloud Storage

MITRE Attack ID:

TA0008: T1080 –
Taint Shared Content

Summary:

Once an attacker is in an environment, they can upload malicious files to cloud storage to infect other users in the environment. This rule is designed to trigger when a cloud storage antivirus detects malware in the cloud storage environment.

Detection Rule:

RQ – Suspicious Process Connecting to Cloud Storage Domain

MITRE Attack ID:

TA0010: T1567.002 –
Exfiltration to
Cloud Storage

Summary:

This rule is designed to detect and alert on suspicious connections to cloud storage domains such as mega.io from unusual processes that may indicate data exfiltration. Attackers will often attempt to exfiltrate data by uploading files to MegaSync storage using custom or renamed tools like rclone.exe. This rule monitors for connections to cloud storage domains from processes not related to web browsers or legitimate cloud storage binaries.

Detection Rule:

RQ – File Uploaded to Cloud Environment with Suspicious User Agent

MITRE Attack ID:

TA0010: Exfiltration

Summary:

This rule is designed to detect file uploads to a cloud environment that utilize suspicious or uncommon User-Agent strings. This may indicate malicious activity such as a red team or threat actor staging tools that will allow them to further their control over an environment.

Containment / Respond Play



Block Hash:

Blocks the hash of a suspicious process and prevents file execution. For malware hosted in cloud services, this should minimize the chance of the incident propagating.



Terminate Active Sessions:

Terminates user's active sign-in session and revokes all cookies. This assists in revoking the threat actor's access to the compromised account.



Reset Password:

Rotates user credentials to hinder the threat actor's ability to continue their activity.

Cloud storage abuse can surface in several ways. The following steps will assist in mitigating a broad array of threats.



Data Loss Prevention (DLP): DLP software monitors and controls the movement of sensitive data to and from cloud storage, thereby preventing unauthorized access and exfiltration. This can mitigate some of the gaps in visibility that EDR may have for cloud services.



Anomaly Detection: Anomaly detection continuously monitors for unusual behaviors and deviations from established baselines, promptly alerting security teams to potential threats and providing a comprehensive view of activities across both endpoints and cloud services.



Comprehensive Usage Policies: Comprehensive usage policies establish clear guidelines and controls for cloud usage, thereby reducing the likelihood of unauthorized and risky behaviors. This could include the enforcement of access controls, user activity monitoring, and regular audits of cloud use.

Targeting Software-as-a-Service Providers

Threat actors exploit customer-supplier relationships in SaaS platforms, often starting with phishing attacks that use sophisticated social engineering to capture login credentials. Once inside, they establish persistence by creating attacker-controlled tenants or compromising administrative accounts. These backdoor accounts ensure ongoing access, making it challenging for security teams to identify malicious activity amidst legitimate operations.

EDR solutions often fail to detect such activity because:

Attackers use legitimate accounts and native tools within the compromised environment, blending in with normal user behavior.

Attackers exploit built-in automation and scripting tools like Microsoft Power Automate or Google Apps Script to execute tasks covertly.

Without adequate oversight, organizations are at heightened risk of data breaches, as attackers can exploit SaaS vulnerabilities to access sensitive information undetected. This lack of visibility complicates threat identification and mitigation, potentially leading to compliance violations, legal penalties, and financial losses.

Inadequate Monitoring Delays:

Incident Response

Containment

Remediation Efforts

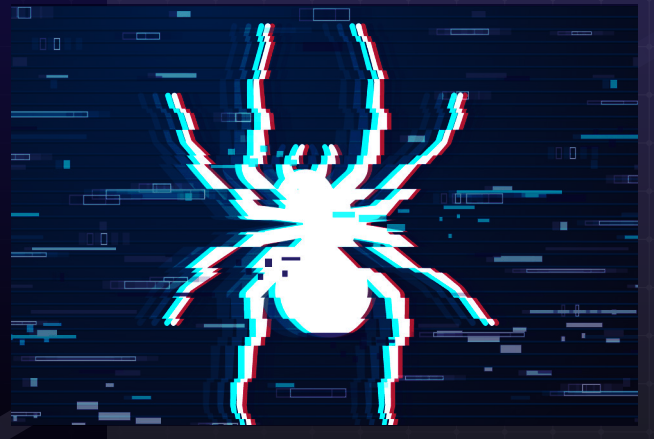
Resulting in Operational Disruptions

The exploitation of built-in automation tools within SaaS environments further exacerbates the risk, enabling attackers to execute malicious tasks without raising alarms.

Ultimately, insufficient SaaS monitoring erodes trust with customers and partners, compromising the organization's reputation and stakeholder relationships.

Case Study

We saw this attack type play out in a June 2024 campaign attributed to the “[Scattered Spider](#)” threat group, a financially motivated cybercriminal organization active since at least May 2022.



In this incident, having achieved initial access (likely using its typical tactics of SMS phishing, SIM swapping, and account hijacking), Scattered Spider reportedly used Okta permissions linked to a compromised account to access the affected company’s cloud and SaaS applications. To maintain persistence, Scattered Spider created new virtual machines on vSphere and Azure, utilizing their admin privileges to configure these machines while also disabling security protections including Microsoft Defender and other telemetry tools.

This enabled the download of other tools used for lateral movement, including Mimikatz and the Impacket framework; Scattered Spider then leveraged legitimate cloud syncing tools such as Airbyte and Fivetran to transfer victim data to their cloud storage on reputable platforms like Google Cloud Platform (GCP) and Amazon Web Services (AWS).

As detailed in previous sections, traditional EDR solutions often lack comprehensive visibility into cloud-based environments and SaaS applications, where much of the activity during this incident took place, allowing the attackers to operate undetected. Additionally, EDR probably failed to detect this incident due to the use of legitimate Okta permissions linked to compromised accounts, making malicious activities appear as routine user behavior. Scattered Spider’s creation of new virtual machines and its disabling of security protections effectively blinded the EDR. Additionally, by employing native tools and legitimate cloud syncing tools, they blended their actions with routine operations, making it difficult for EDR to flag their activities as suspicious.

This case study showcases several of the techniques mentioned in this report:

Targeting Legitimate
and Susceptible Email
Accounts

Leveraging Native Tools and
Existing Relationships with
SaaS Providers

Using Reputable
Cloud Providers for
Data Exfiltration

Much of this activity heavily relies on social engineering, as the human element is often the initial vulnerability exploited by threat actors. The ability to “live off the land,” modifying security tools while also frequently adapting their techniques, makes Scattered Spider a sophisticated and resourceful adversary whose attacks are difficult to detect through traditional security solutions like EDR. Staying on top of developing threat actor techniques is crucial because their methods change rapidly, requiring continuous adaptation to effectively defend against emerging cyber threats.

Mitigations and Recommendations

The following respond plays and detections provide mitigation against threat actor activities after accessing SaaS applications.

Detection Rule: RQ – Security Tool Disabled

MITRE Attack ID:

T1562 –
Impair Defenses

Summary:

After attackers gain access to a host in an environment, they will often move to disable security tools on the host. This rule looks for attempts to disable security tools installed on systems.

Detection Rule: RQ – Okta Login Denied by Policy

MITRE Attack ID:

N/A

Summary:

This will trigger an alert when an Okta login was initially successful but was then denied by policy. Example: User inserts their password successfully, but it is denied because they are authenticating from a restricted country (or off hours).

Detection Rule: RQ – Mimikatz Detected

MITRE Attack ID:

TA0006: T1003.001 –
LSASS Memory

TA0008: T1550.003 –
Pass the Ticket

TA0008: T1550.002 –
Pass the Hash

Summary:

This alert detects activity associated with the hacking tool Mimikatz. The tool loads a combination of unique Dynamic Link Library files (DLLs) that can be used to identify its execution along with various commands that can be seen when an adversary is running it. Mimikatz is a popular tool for attackers to steal credentials from the local host.

Containment / Respond Play



Isolate Host:

Isolates a compromised host, cutting off the threat actor's ability to communicate with the network, thereby preventing further spread and data exfiltration.



Terminate Active Sessions:

Terminates user's active sign-in session and revokes all cookies. This assists in revoking the threat actor's access to the compromised account.



Reset Password:

Rotates user credentials to hinder the threat actor's ability to continue their activity.

Detecting threat actor abuse of SaaS can be challenging. The recommendations that will provide the greatest remediation against these risks likely involve taking proactive steps to improve overall security maturity.



Principle of Least Privilege: Organizations should adopt the principle of least privilege by granting users only the minimum access necessary to perform their job function. Regular audits of access permissions ensure they remain appropriate and do not pose unnecessary risks; this will assist with identifying any suspicious accounts that have been fraudulently established by threat actors.



CASBs: CASBs can provide visibility and control over data and activities within SaaS applications by enforcing security policies, monitoring user behavior, and detecting anomalies that might indicate abuse.



Application Security Posture Management (ASPM): Regular assessment and improvement of SaaS application security posture can minimize vulnerabilities and exploitable misconfigurations. Vulnerability scans and security audits can help security teams to identify and remediate potential weaknesses. It's also important to rigorously evaluate the security posture of third-party vendors and integrations to ensure they meet an organization's security requirements.

Insider Threats

Insider threats originate from individuals who have legitimate access to sensitive systems and data. The motivations of an insider—and impact of their actions—can vary greatly. Malicious insiders intentionally exploit their legitimate access to inflict harm on the organization, often motivated by personal gain, revenge, or coercion. Reckless insiders disregard organizational policies and security protocols, knowingly engaging in risky behavior that can endanger the organization's security, though not necessarily with intent to harm. Accidental insiders unintentionally compromise security through negligence, errors, or lack of awareness, such as falling victim to phishing attacks or mishandling sensitive information. Whatever the motivation, an attack involving insiders typically results in a security breach from within an organization.

EDR solutions are primarily designed to identify and mitigate threats originating from outside the organization. Unlike external attackers, insiders—whether malicious employees, contractors, or partners—do not need to breach perimeter defenses to carry out their activities. Since insider threats usually operate within the bounds of legitimate user behavior, it is difficult for EDR solutions to flag their actions as suspicious. For instance, a malicious insider might exfiltrate data using authorized access methods or leverage existing administrative tools to cover their tracks—activities that would appear normal to an EDR system.

The ability to blend in with normal operations and avoid triggering security alerts makes insider threats particularly insidious and difficult to counter with traditional security solutions alone. Information related to insider threats is routinely posted on cybercriminal forums, where insiders working in specific sectors or companies are requested or advertised (see Figure 4).

In many cases, the impacted company is not named; instead, the threat actor specifies a sector and geography. This leaves fewer opportunities for security researchers and defenders to act proactively. The implications of a publicly exposed insider threat are significant, potentially resulting in severe reputational damage, regulatory penalties, and substantial financial losses.

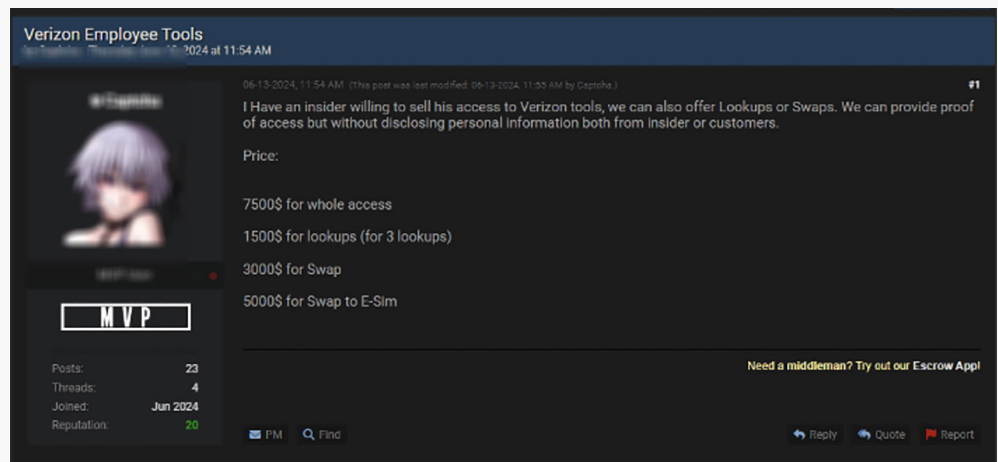


Figure 4: Insider selling access to US-based telecommunications company

Case Study

A recent ReliaQuest-handled incident exemplifies the dangers of insider threats.

ReliaQuest identified suspicious connections in a customer environment reaching out to high-risk domains with no business relationship.



An investigation into the methods used to initiate these connections, including associated processes, execution chains, and connection frequency, revealed SSH connections to two domains, linked to an internal user, occurring over several months. The top-level domain (TLD) of these connections and their lack of prevalence within the environment indicated suspicious activity. Sandbox analysis revealed that one domain led to a torrenting site associated with qBittorrent, while the other was linked to Nextcloud, a platform providing client-server software for file hosting services. Artifacts surrounding activity associated with the Nextcloud domain indicated internal data was being synced with external storage. After coordinating with the associated customer, ReliaQuest confirmed the activity was unauthorized and that the domains in question were owned by the identified internal user.

The identified activity did not suggest actions by an external threat actor but rather internal users violating acceptable use policies. The motivations of the employee were unclear, but likely aligned with those of a malicious or reckless insider, knowingly transferring sensitive data outside the organization's network boundaries. At this point, the customer continued the investigation internally.



Figure 5: Domain observed in the incident led to torrenting service qBittorrent

There are several reasons for EDR's lack of visibility in this case study. First, the use of file transfer protocol (FTP) for data exfiltration can appear as legitimate network activity, especially if the internal user has authorized access to the data being transferred. Second, the suspicious connections flagged were associated with an internal user, making connections over port 22, which is commonly used for Secure Shell (SSH) and other legitimate purposes. Using the protocol for normal—though, in this case, undesirable—actions might not trigger EDR alerts. Additionally, the activity involved reaching out to domains that could be perceived as legitimate but that were actually linked to the torrenting sites qBittorrent and Nextcloud.

EDR solutions often focus on external threats and malware, potentially overlooking policy violations and insider threats when they mimic routine operations. Lastly, the EDR may not have been configured to monitor or flag acceptable use policy violations, further hindering its ability to detect this insider activity. The combination of insider knowledge and potentially destructive motivations makes insiders one of the biggest risks to an organization. It's critical to monitor insider activities and understand that traditional security measures may not always detect internal threats.

Organizations need comprehensive security strategies that include user behavior analytics, strict access controls, and regular audits to detect anomalies. Organizations should also implement robust acceptable use policies and ensure that employees are aware of the security implications of their actions. Additionally, integrating security solutions that offer deep visibility into both user activities and network traffic can help identify suspicious behavior early. Because insider threats requires a focus on both prevention and detection, combining technical controls with ongoing employee education and awareness initiatives can more comprehensively protect organizations.

Mitigations and Recommendations

The best detections for insider threats are related to email and DLP policies, which we've detailed below.

Detection Rule: RQ – Email DLP Policy Violation

MITRE Attack ID:

M1057

Summary:

Detects 10 or more DLP violations coming from personal email accounts. For example, the transmission of sensitive data, an improper email recipient, or file exceeding attachment size limits.

Detection Rule: RQ – Data Exfiltration to Unsanctioned Apps

MITRE Attack ID:

M1057

Summary:

This rule detects potential data exfiltration by a user to an unsanctioned cloud storage app through an existing CASB alert.

Detection Rule: RQ – Multiple Blocked File Sharing Attempts

MITRE Attack ID:

TA0010: T1567.002 –
Exfiltration to
Cloud Storage

Summary:

Navigation to multiple file-sharing sites could indicate that a threat actor has established a foothold within an environment and is attempting to exfiltrate sensitive data.

Most networks block traffic that is classified as file sharing and storage, so multiple blocked traffic events to unique file-sharing sites could indicate an active threat within the environment attempting to exfiltrate data. This rule looks to detect multiple attempts to domains that are categorized as file sharing services.

Containment / Respond Play



Block Recipient:

Blocks a suspicious recipient of outbound data. For insider threats, this minimizes the chances of sensitive data being breached.



Block Domain:

Terminates user's active sign-in session and revokes all cookies. This assists in revoking the insider's access to the compromised account.



Disable User:

Disables a user if there are severe concerns regarding their activity—including that which is deemed to present an insider risk.

Managing the risk from insiders is best achieved through strict account management and comprehensive access policies.



Access Control Lists (ACLs): ACLs can restrict FTP usage to only authorized users. They can also enhance security by defining and enforcing user permissions, thereby reducing gaps in visibility for EDR solutions and ensuring only authorized users can access sensitive resources.



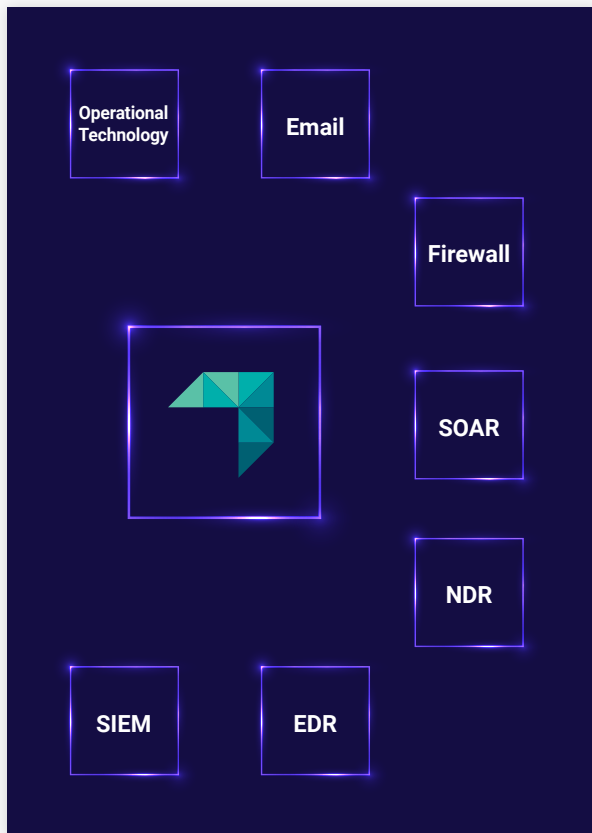
Privileged Access Management (PAM): PAM assists in managing insider threats by enforcing strict access controls and real-time monitoring of privileged activities. It also plugs visibility gaps that traditional EDR solutions may have by providing detailed oversight of privileged account usage.



Joiners, Movers, Leavers (JML) Processes: JML processes help manage insider threats by ensuring that access rights are appropriately assigned, reviewed, and revoked as employees join, change roles in, or leave the organization, thereby plugging gaps that EDR may have in tracking and controlling user permissions.

Conclusion

While EDR tools excel at monitoring, detecting, and responding to endpoint threats in real time, they fall short in providing comprehensive visibility and protection across network traffic, cloud environments, and coordinated multivector attacks. To overcome these limitations, EDR must be bolstered by additional security measures. Attackers are becoming increasingly agile, employing sophisticated techniques that easily bypass traditional security solutions. In the face of these evolutions, relying solely on EDR is no longer sufficient. Instead, adopting a proactive approach and implementing measures to improve visibility can make the difference between merely detecting a threat and its becoming a full-blown incident.



The ReliaQuest GreyMatter security operations platform enhances visibility across environments, provides automated playbooks that work with your existing tech stack through bi-directional integrations, and continuously monitors security operations for gaps and improvements. This can be indispensable for closing visibility gaps in traditional EDR systems while effectively mitigating threats.

This includes GreyMatter DRP, which assists users by continuously monitoring open and closed sources, identifying threats, and providing actionable insights. Traditional security measures often operate in silos, resulting in fragmented data and blind spots that can be exploited by sophisticated attackers. GreyMatter consolidates and correlates data from multiple sources—including endpoints, networks, and cloud environments—to provide a unified and comprehensive view of the entire security landscape. This unification allows for more accurate detection of anomalous activities and potential threats that might otherwise go unnoticed.

By employing artificial intelligence (AI), machine learning, and threat intelligence, GreyMatter enhances the ability to identify and respond to complex attack vectors in real time. Additionally, GreyMatter automates many aspects of threat detection and response, reducing the workload on security teams and enabling quicker remediation of incidents.

This not only improves the overall security posture but also ensures that organizations can swiftly and effectively counteract emerging threats, thereby safeguarding their critical assets and maintaining operational integrity. In our [2024 Annual Threat Report](#), we identified that customers using at least some level of AI and automation saw a reduction in their MTTR to 58 minutes, which is down 98.8% from 2022. Those who are fully leveraging AI and automation, however, have brought their MTTR down to 7 minutes or less.

[Read more about how GreyMatter can assist your organization.](#)

Appendix: Endnotes

1. Security frameworks that operate on the principle of “never trust, always verify,” requiring strict identity verification for every user and device attempting to access resources, regardless of whether they are inside or outside the network perimeter.
2. A promise-based HTTP client is a software library or tool that facilitates making HTTP requests (such as GET, POST, PUT, DELETE) and handles asynchronous operations using promises.